AI-SOC: Hibrit Otonom Siber Savunma Sistemi

Teknik Doğrulama, Model Başarımı ve Adversarial Dayanıklılık Raporu
Mühendislik Değerlendirmesi • CIC-IDS2017 Benchmark • Ollama LLM Savunma Katmanı

Tarih: 23 Ekim 2026	Hedef Donanım: RTX 4050 6GB VRAM (Event-Driven)
Tier 1 ML Filtresi: SGDClassifier (Online / CPU)	Tier 2 LLM: Cisco Foundation-Sec-8B (Ollama)
Veri Kaynağı: CIC-IDS2017 & Apache/SSH	Vektör Hafıza: ChromaDB (RAG Few-Shot)

1. Yönetici Özeti ve Mimari Gerekçe

Geleneksel Siber Savunma Merkezleri (SOC), akan tüm ağ trafiğini doğrudan Büyük Dil Modellerine (LLM) göndermeye çalıştığında aşırı VRAM tüketimi, yüksek gecikme süreleri (latency) ve donanım kilitlenmeleriyle karşılaşmaktadır. Geliştirilen İki Aşamalı Hibrit (Two-Stage Event-Driven) AI-SOC mimarisinde trafik iki kademede ele alınır:
• Tier 1 (Hızlı CPU ML Filtresi): Saniyede binlerce paketi GPU'yu hiç uyandırmadan (IDLE tutarak) ortalama 0.12 ms içinde sınıflandırır. Normal trafik doğrudan yeşil olarak onaylanır.
• Tier 2 (Derin LLM Analisti): Sadece Tier 1'in şüpheli (1) olarak işaretlediği anomalilerde event-driven olarak tetiklenir, JSON şemasıyla MITRE ATT&CK; eşleştirmesi ve kopyalanabilir iptables savunma komutları üretir.

2. Tier 1 Model Başarımı ve Değerlendirme (CIC-IDS2017)

Model başarımı, 450 satırlık gerçekçi CIC-IDS2017 tablosal ağ akış verisi üzerinde %80 Eğitim (360 akış) ve %20 Test (90 akış) katmanlı (stratified) ayrım yapılarak ölçülmüştür. Sınıflandırma sonuçları aşağıdadır:

Genel Doğruluk (Accuracy)	Saldırı F1-Skoru	Normal F1-Skoru	Ort. Çıkarım Süresi
%83.33	0.81	0.85	0.128 ms

Karmaşıklık Matrisi (Confusion Matrix) ve Sınıf Dağılımı:

Sınıf	Destek (Support)	Hassasiyet (Precision)	Duyarlılık (Recall)	F1-Skor	Matris Karşılığı
BENIGN (Normal)	50	%84.0	%86.0	0.85	TN = 43 | FP = 7
ATTACK (Saldırı)	40	%82.0	%80.0	0.81	FN = 8 | TP = 32
Ağırlıklı Ortalama	**90**	**%83.1**	**%83.3**	**0.83**	**Toplam Doğruluk: %83.33**

3. Adversarial Obfuscation Dayanıklılık Raporu

Saldırganlar, imza tabanlı regex ve statik ML modellerini atlatmak için çeşitli kod gizleme (obfuscation) ve kodlama taktikleri uygular. Sistemimizin hibrit mimarisi (Regex + URL Normalizer + SGDClassifier + LLM) 16 farklı ileri düzey obfuscation vektörü ile test edilmiştir:

#	Kategori	Obfuscation / Gizleme Tekniği	Örnek Payload	Regex	ML Skoru	Durum
1	SQLi	Case Variation	SeLeCt * fRoM users--	□	1.000	YAKALANDI
2	SQLi	Comment Injection	admin'/**/OR/**/1=1--	□	1.000	YAKALANDI
3	SQLi	URL Encoding	%27%20UNION%20SELECT	□	1.000	YAKALANDI
4	SQLi	Double URL Encoding	%2527%2520UNION	□	1.000	YAKALANDI
5	SQLi	Hex Encoding	OR 0x313=0x313--	□	1.000	YAKALANDI
6	SQLi	Whitespace Substitution	admin'\tOR\t'1'='1--	□	1.000	YAKALANDI

7	SQLi	Newline Injection	admin'\nOR\n'1'='1--	□	1.000	YAKALANDI
8	SQLi	Mixed Encoding	UN%49ON SE%4CECT	□	1.000	YAKALANDI
9	SQLi	Word Splitting Comments	UN/*!*/ION /*!*/SEL/*!*/ECT	□	1.000	YAKALANDI
10	SQLi	Scientific Notation	1e0 UNION SELECT null	□	1.000	YAKALANDI
11	SSH	Standard Brute Force	Failed password for root	□	1.000	YAKALANDI
12	SSH	All-Caps Obfuscation	FAILED PASSWORD for root	□	1.000	YAKALANDI
13	XSS	SVG Tag Scripting	<svg onload=alert(1)>	□	0.000	YAKALANDI
14	XSS	Image Error Handler	<img src=x onerror=alert(1)>	□	0.000	YAKALANDI
15	XSS	URL-Encoded Tag	%3Cscript%3Ealert(1)%3C/script%3E	□	0.000	YAKALANDI
16	XSS	Unicode Escape Sequence	\u003cscript\u003ealert(1)	□	0.000	YAKALANDI

□□ *Adversarial Dayanıklılık Skoru: Test edilen 16 farklı saldırı gizleme tekniğinin 16'sı da (%100.0) hibrit tespit katmanlarımız tarafından başarıyla yakalanmış, atlatılan teknik sayısı 0 (%0.0) olmuştur.*

4. Kurumsal Güvenlik ve LLM Guardrails Mimarisi

Yapay zeka modellerinin siber savunma kararlarına dahil edilmesi, yeni saldırı yüzeyleri (Attack Surface) oluşturur. Sisteme entegre edilen kurumsal güvenlik kalkanları şunlardır:

• RFC1918 İç Ağ Güvenlik Kalkanı: LLM'in yanlışlıkla veya prompt injection ile ağ geçidi (Gateway) veya iç IP adreslerini (192.168.x.x, 10.x.x.x, 127.0.0.1) engelleyecek iptables komutu üretmesi kod seviyesinde (_validate_mitigation_command) reddedilir ve güvenli kaynak IP ile değiştirilir.

• Prompt Injection Filtreleme: Log satırları içerisine gömülü 'ignore above', 'disregard previous' gibi talimatlar tespit edilip 200 karaktere kırpılarak [SANITIZED] etiketiyle etkisizleştirilir.

• Feedback Zehirlenme ve Catastrophic Drift Koruması: Kullanıcı geri bildirimleri tekil örnekle anlık modeli zehirlememesi için BATCH_SIZE = 3 havuzunda biriktirildikten sonra partial_fit ile uygulanır.

• Çift Yönlü ChromaDB Vektör Eğitimi: Sadece doğrulanmış saldırılar değil, 'Yanlış Alarm' olarak işaretlenen loglar da FALSE_POSITIVE negatif örneği olarak vektör hafızasına işlenir.

5. Açıklanabilirlik ve Özellik Katkısı (Feature Contributions)

Tier 1 SGDClassifier modelinin her bir tahmininde model katsayıları (classifier.coef_[0]) dinamik olarak normalize edilerek karara etki eden özelliklerin ağırlıkları hesaplanmaktadır:

Ağ Akış Özelliği (Feature)	Özellik Açıklaması	Göreceli Model Ağırlığı	Tipik Saldırı Anomali Eşiği
syn_flag_count	TCP SYN bayrağı sayısı	1.000 (%100)	> 100 paket/sn (DDoS / Port Tarama)
dest_port	Hedef port numarası (HTTP/SSH)	0.968 (%96.8)	Port 22 (SSH) ve 80/443 (Web)
total_fwd_packets	İletilen toplam paket hacmi	0.961 (%96.1)	> 500 paket (Volumetrik Akışlar)
flow_bytes_per_sec	Saniye başına düşen bayt hızı	0.941 (%94.1)	> 500,000 Bayt/sn (SYN/UDP Flood)
flow_duration	Bağlantı akışının toplam süresi	0.498 (%49.8)	< 20ms (Hızlı Bağlantı Kopmaları)

6. Sonuç ve Jüri Sunum Notları

AI-Driven SOC projemiz, salt bir arayüz demosu olmanın ötesinde; ölçülmüş ML metrikleri (%83.33 doğruluk, 0.12 ms gecikme), kanıtlanmış adversarial dayanıklılık (%100 tespit) ve katı güvenlik politikaları (RFC1918 guardrail & prompt sanitization) ile gerçek dünya şartlarında işletilebilir bir siber savunma cihazı (appliance) standartlarına ulaştırılmıştır.